Lab 5: Static Code Analysis

Student: Pruthviraj H

SRN: PES2UG24CS381

Program: pharmacy_system.py

This report documents the use of Pylint, Bandit, and Flake8 to improve the quality, security, and style of a small pharmacy stock tracker.

Issue Table

Issue	Type	Line(s)	Description	Fix approach
SQL injection risk	Security	21	User input was joined directly into an SQL query.	Used a parameterized query.
Mutable default argument	Bug	24	A default list was shared across calls.	Used None and created a new list.
Bare exceptions	Reliability	38, 58	Errors were hidden by bare except blocks.	Caught only expected exception types.
Unsafe file handling	Quality	50, 57	Files lacked context managers and encoding.	Used with blocks and UTF-8 encoding.
Style and unused import	Style	3, multiple	Unused os import and naming/spacing issues.	Removed, renamed, and formatted code.

Final Results

Tool	Result
Pylint	10.00/10
Bandit	No issues identified
Flake8	No issues identified

Reflection

1. What is static code analysis?

Static code analysis checks source code without running the program. It can find style problems, likely bugs, unsafe coding patterns, and maintainability issues early in development.

2. Which finding was most important and why?

The SQL injection warning was most important because user input was placed directly into a database query. Parameterized SQL prevents the input from being interpreted as part of the command.

3. How did the tools differ?

Pylint gave a broad review of code quality, naming, documentation, and design. Flake8 focused on syntax and PEP 8 formatting. Bandit focused on security-sensitive patterns.

4. What did this lab teach you?

The tools find different categories of problems, so using them together gives better coverage. A program can run successfully and still contain security, reliability, and maintainability problems.

Analyzer Output

pylint_report.txt

```
--------------------------------------------------------------------
Your code has been rated at 10.00/10 (previous run: 10.00/10, +0.00)
```

bandit_report.txt

```
Run started:2026-10-16 14:40:50.093592+00:00

Test results:
■No issues identified.

Code scanned:
■Total lines of code: 97
■Total lines skipped (#nosec): 0
■Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
■Total issues (by severity):
■■Undefined: 0
■■Low: 0
■■Medium: 0
■■High: 0
■Total issues (by confidence):
■■Undefined: 0
■■Low: 0
■■Medium: 0
■■High: 0
Files skipped (0):
```

flake8_report.txt

```
No findings.
```